

AI Risk Analyst

1. Why Traditional IT Risk Frameworks Fall Short for AI

Risk analysis in traditional IT is a mature discipline with established methodologies — FAIR, ISO 31000, NIST SP 800-30 — and decades of empirical data on threat likelihood and impact. AI introduces risk categories that these frameworks were not designed to address. Adversarial manipulation of model behavior, training data poisoning, privacy leakage through model outputs, model supply chain compromise, and risks arising from bias or miscalibrated confidence are AI-specific phenomena with no direct analogs in traditional IT risk taxonomy.

This gap matters practically: an organization that performs a traditional IT risk assessment on an AI system will systematically underestimate its risk exposure. The AI Risk Analyst role exists to fill this gap — applying risk assessment methodology to AI-specific risk categories and providing organizations with the structured risk understanding that security and governance decisions depend on. For SecAI+ practitioners, understanding the AI Risk Analyst's methodology is essential to understanding why specific security controls exist and what they are designed to prevent.

2. The AI Risk Taxonomy: Five Categories

Risk Category	AI-Specific Examples	Assessment Approach
Technical	Adversarial attacks, training data poisoning, model privacy violations, model underperformance on distribution-shifted inputs	MITRE ATLAS v2.1 threat library; red team testing; adversarial robustness evaluation
Operational	AI service availability, data quality degradation in production, model drift, AI supply chain failures	Dependency mapping; SLA analysis; model monitoring metrics
Compliance	EU AI Act violations, data protection failures, sectoral AI regulations in finance and healthcare	Regulatory inventory; gap analysis against applicable frameworks
Reputational	Harmful or discriminatory model outputs becoming publicly known; AI system public failure	Scenario modeling; stakeholder impact analysis
Strategic	Over-dependence on AI systems, vendor lock-in through proprietary AI platforms, AI capability gaps versus competitors	Architecture review; vendor concentration analysis; competitive benchmarking

NIST AI RMF 1.0's MAP function provides the methodology for systematically identifying risks across these categories. The AI Risk Analyst operationalizes this function — translating the MAP function's requirements into specific assessment activities tailored to the organization's AI portfolio and deployment context.

3. Risk Assessment Methodology for AI Systems

AI Risk Analysts apply structured risk assessment methodology adapted from established frameworks to the AI context. The six-step methodology the SecAI+ exam tests is:

- Step 1 — Asset identification: Identify all AI assets and their threat exposure surface. This includes models in production, models in development, training datasets, model registries, inference APIs, and third-party AI services the organization depends on.
- Step 2 — Threat identification: Map identified assets to applicable threats using MITRE ATLAS v2.1 and OWASP LLM Top 10 v1.1 as primary threat libraries. These provide curated catalogs of real-world adversarial ML attack patterns that go beyond what traditional IT threat libraries cover.
- Step 3 — Likelihood estimation: Estimate the probability that each identified threat will materialize, given the organization's specific deployment context, existing controls, and threat actor profile. This step is where AI-specific expertise matters most — likelihood estimates for novel attack patterns require analyst judgment rather than actuarial data.
- Step 4 — Impact estimation: Estimate the consequence if the threat materializes. Impact for AI systems includes direct operational impact, regulatory penalties, reputational damage, and in high-stakes domains (healthcare, critical infrastructure), potential harm to individuals.
- Step 5 — Risk calculation: Calculate risk as a function of likelihood and impact. Most AI risk programs use either qualitative severity tiers or quantitative probability-weighted expected loss — or a hybrid of both.
- Step 6 — Risk treatment prioritization: Prioritize risks for treatment based on calculated risk levels and organizational risk appetite. Treatment options — accept, mitigate, transfer, avoid — are the same as traditional risk management but the specific controls differ.

4. MITRE ATLAS and OWASP LLM Top 10: The AI Threat Libraries

Two threat libraries are specifically tested in the SecAI+ exam context for AI risk assessment:

Library	Publisher	Scope	Key Value for Risk Analysts
MITRE ATLAS v2.1	MITRE Corporation	Adversarial ML attacks against AI systems — model evasion, poisoning, inversion, extraction	Grounded in real-world incidents; provides attack patterns with documented real examples; maps to MITRE ATT&CK for integration with existing threat intelligence
OWASP LLM Top 10 v1.1	OWASP Foundation	Top 10 security risks specific to Large Language Model applications	Covers prompt injection, insecure output handling, training data poisoning, model denial of service, supply chain vulnerabilities — critical for organizations deploying LLM-based applications

MITRE ATLAS was designed specifically to address the gap in MITRE ATT&CK for AI systems. ATT&CK covers traditional IT attack techniques; ATLAS extends the framework to cover the adversarial machine

learning attack surface. AI Risk Analysts who use only traditional IT threat libraries — MITRE ATT&CK, OWASP Top 10 for web applications — will systematically miss AI-specific attack patterns.

5. Quantitative vs. Qualitative AI Risk Assessment

Dimension	Quantitative Assessment	Qualitative Assessment	Hybrid Approach
Expression	Probability-weighted expected losses (e.g., 15% probability × \$2M impact = \$300K risk exposure)	Severity tiers: Critical / High / Medium / Low / Informational	Qualitative tiers for novel AI risks; quantitative modeling for operational/compliance risks with historical data
Data requirement	Reliable empirical data on threat likelihood and impact — often unavailable for novel AI attacks	Expert judgment with defined tier criteria — more tractable for emerging threats	Match method to data availability per risk category
Strengths	Rigorous comparison; supports ROI analysis for controls; defensible to finance and board stakeholders	Tractable for novel risks; faster to produce; understandable to non-technical stakeholders	Balances rigor with tractability; appropriate for AI risk programs in most organizations
Weaknesses	False precision when input data is unreliable; complex to maintain	Rankings harder to justify; comparison across categories less rigorous	Requires analyst discipline to apply consistently across risk types

SecAI+ exam questions about risk methodology may ask candidates to identify which approach is appropriate for a given scenario. The key signal: if empirical data on the specific threat is available and reliable, quantitative is preferred. If the risk involves novel AI attack patterns without historical base rates, qualitative or hybrid is more appropriate.

6. AI Risk in High-Stakes Deployment Domains

Domain	Key AI Risk Categories	Applicable Regulations
Healthcare	AI misdiagnosis, AI-induced treatment delays, model bias causing disparate diagnostic accuracy, training data privacy violations	HIPAA, EU AI Act Annex III (medical devices), FDA AI/ML guidance
Financial Services	Discriminatory lending (disparate impact), market manipulation through AI trading, credit scoring bias, model risk violations	EU AI Act Annex III, US SR 11-7 (Federal Reserve model risk), Fair Housing Act, Equal Credit Opportunity Act
Critical Infrastructure	AI system availability in safety-critical contexts, AI-enabled attacks on industrial control systems, AI supply chain compromise	EU AI Act Annex III (critical infrastructure), NERC CIP, sector-specific regulations

Law Enforcement	Discriminatory facial recognition, biased risk scoring for bail/parole, AI-enabled civil liberties violations	EU AI Act Article 5 (prohibited uses), Fourth Amendment (US), human rights law
-----------------	---	--

7. Named Incident: Credit Scoring Disparate Impact (2023)

Financial Institution — AI Credit Scoring Bias (2023): An AI-based credit scoring system deployed by a large financial institution was found in 2023 to systematically disadvantage borrowers from specific zip codes — a proxy for protected demographic attributes (race and national origin). The AI Risk Analyst who reviewed the system pre-deployment had assessed data poisoning and adversarial attack risks but had not assessed disparate impact risk, which was not included in the organization's AI risk framework at the time. The system had been operating for over 18 months before the pattern was identified through a regulatory examination. The organization faced regulatory action, substantial remediation costs, and reputational damage. The lesson: AI risk frameworks must explicitly include fairness and bias risks — they cannot assume that technical performance metrics capture all relevant risks. NIST AI RMF's MAP function specifically requires identifying sociotechnical risks alongside technical risks.

8. How Risk Assessments Fail: Red Team Perspective

Risk assessments can fail in ways that create dangerous false confidence — not because of incompetence but because of systematic patterns that experienced AI Risk Analysts learn to guard against. Red teams evaluating an organization's AI risk program probe for:

- **Incomplete threat scope:** Risk registers include only the risks the analyst thought to include. If MITRE ATLAS threat patterns were not consulted, AI-specific attack categories will be systematically absent — making the risk register look comprehensive while covering only traditional IT risks.
- **Optimistic likelihood estimates:** Assessments reflect organizational optimism rather than empirical evidence. Teams whose AI systems have not yet been attacked tend to underestimate attack likelihood — until the first incident changes the estimate retroactively.
- **Truncated impact estimates:** Impact calculations exclude indirect consequences — regulatory penalties, reputational damage, operational disruption from dependencies on the compromised AI system. Direct impact is assessed; total impact is understated.
- **Unimplemented treatment plans:** Risk registers document treatment actions that were never implemented or implemented incorrectly. The risk is nominally managed; the actual exposure remains unchanged.
- **Static assessment treated as ongoing process:** The most dangerous failure is treating risk assessment as a one-time checkbox exercise. Risk landscapes change as new attack techniques are demonstrated and as the organization deploys new AI capabilities.

Memory Anchor — Insurance Actuary: An AI Risk Analyst functions like an insurance actuary: they provide probability-weighted assessments of risk that inform pricing (where to invest in controls) and policy (what risks the organization will accept). An actuary who stops collecting data and relies on historical assessments from three years ago is providing increasingly unreliable estimates. The AI Risk Analyst who treats their last

assessment as current faces the same problem.

9. Responsible Practice: Documenting Unfavorable Assessments

AI Risk Analysts occupy a position analogous to actuaries or credit analysts — they provide risk assessments that inform organizational decisions, but they are not the final decision-makers. This creates a specific responsible use tension: what do they do when decision-makers choose to accept risks that the analyst has assessed as unacceptably high?

- Formal documentation of risk assessments: All risk assessments — including those with findings that business stakeholders would prefer to minimize — must be documented formally and retained as governance records.
- Explicit documentation of override decisions: When organizational decision-makers accept risks that the analyst recommended treating, this decision must be explicitly documented, including who made the decision and their stated rationale.
- Analyst integrity: AI Risk Analysts who soft-pedal unfavorable risk assessments to avoid conflict with business stakeholders are not fulfilling their function. The assessment must accurately represent the analyst's professional judgment, not the result the stakeholder wants.
- Personal audit trail: Formal documentation protects both the organization and the analyst. If regulatory action follows a risk event, documented risk assessments showing the analyst identified and reported the risk — even if management accepted it — demonstrate that the analyst fulfilled their obligation.

10. Integration with Governance, Security, and Audit Functions

AI Risk Analysts do not operate in isolation. Their risk assessments are inputs to three downstream functions:

- AI Governance Engineer: Implements technical controls to mitigate the risks the analyst has identified. The governance engineer's control selection should be directly traceable to specific risk assessment findings — not a generic control catalog applied without regard to the organization's specific risk profile.
- AI Security Architect: Designs security architecture against the threat landscape the analyst has identified. Security architecture decisions — which models to isolate, which inference APIs to protect, which supply chain elements to validate — should be informed by risk assessment priorities.
- AI Auditor: Verifies that risk treatment actions identified in the assessment were actually implemented and are operating effectively. The audit function closes the loop on the risk management cycle — ensuring that identified risks result in implemented, effective controls.

Organizations using NIST AI RMF 1.0 implement this integration through the MAP → MEASURE → MANAGE cycle. The AI Risk Analyst primarily operates in MAP (identifying and characterizing risks) and MEASURE (quantifying risk levels). Governance and security functions operate in MANAGE (treating identified risks). The Audit function verifies the cycle was followed correctly. This is a formal process requiring documented outputs at each stage — not ad hoc communication.

Key Terms Glossary

Term	Definition
NIST AI RMF 1.0	US voluntary AI risk management framework with four functions: GOVERN, MAP, MEASURE, MANAGE
MAP Function	NIST AI RMF function for identifying and characterizing AI risks — the primary function the AI Risk Analyst operationalizes
MITRE ATLAS v2.1	MITRE's adversarial ML threat knowledge base — curated library of real-world attack patterns against AI systems, analogous to MITRE ATT&CK for traditional IT
OWASP LLM Top 10 v1.1	OWASP's ranked list of the top 10 security risks specific to Large Language Model applications, including prompt injection and training data poisoning
Disparate Impact	Statistical measure of whether model outcomes differ significantly across protected demographic groups — a compliance and fairness risk category distinct from technical performance
Sociotechnical Risk	NIST AI RMF term for risks arising from the interaction of AI systems with social systems and human actors — including bias, discrimination, and misuse
Likelihood Estimation	Risk assessment step of estimating the probability that an identified threat will materialize, given the organization's specific context and controls
Risk Treatment	Action taken in response to an identified risk — accept, mitigate, transfer, or avoid — each with different resource and residual risk implications
SR 11-7	Federal Reserve guidance on model risk management — applies traditional model risk principles to AI/ML models in financial services
Quantitative Risk Assessment	Risk methodology expressing risks as probability-weighted expected losses — more rigorous but requires reliable empirical data on threat likelihood and impact
Qualitative Risk Assessment	Risk methodology categorizing risks into severity tiers without numerical estimates — more tractable for emerging AI risks without empirical base rate data
Risk Register	Documented inventory of identified risks, their assessed likelihood and impact, treatment decisions, and assigned owners — the primary output of the AI risk assessment process

Quick Revision Checklist

- AI Risk Analysts assess five risk categories: technical, operational, compliance, reputational, and strategic.
- NIST AI RMF MAP function is the primary methodology AI Risk Analysts operationalize — identifying and characterizing AI risks.

- Two key threat libraries: MITRE ATLAS v2.1 (adversarial ML attacks) and OWASP LLM Top 10 v1.1 (LLM-specific risks).
- Risk assessment methodology: asset identification → threat identification → likelihood estimation → impact estimation → risk calculation → treatment prioritization.
- Quantitative assessment preferred when empirical data available; qualitative for novel AI attack patterns without historical base rates.
- High-stakes domains: healthcare (HIPAA, EU AI Act Annex III), financial services (SR 11-7, disparate impact), critical infrastructure, law enforcement.
- The 2023 credit scoring disparate impact case demonstrates that fairness/bias risks must be explicitly included in AI risk frameworks — not assumed captured by performance metrics.
- Risk assessment failures: incomplete threat scope, optimistic likelihood, truncated impact, unimplemented treatments, static assessment treated as ongoing.
- Formal documentation of both risk assessments and override decisions protects the analyst and the organization.
- AI Risk Analysts integrate with Governance Engineers (control implementation), Security Architects (architecture decisions), and Auditors (verification).
- NIST AI RMF cycle: MAP (Risk Analyst) → MEASURE (Risk Analyst) → MANAGE (Governance/Security) → verified by Auditor.

10 Exam-Based MCQs — AI Risk Analyst

These questions are written in SecAI+ exam style — scenario-heavy, with plausible distractors. Read every explanation.

Q1. Scenario: A financial services firm deploys an AI credit scoring system. The pre-deployment risk assessment identified and addressed data poisoning and adversarial attack risks. The organization later faces regulatory action when the model is found to systematically disadvantage borrowers from protected demographic groups. The CISO asks the AI Risk Analyst to explain what was missed. An AI Risk Analyst reviewing a credit scoring model identifies data poisoning and adversarial evasion risks but does not include disparate impact in the risk assessment. Six months later, the model is found to systematically disadvantage borrowers from specific zip codes. Which assessment failure MOST directly caused this outcome?

- A) The analyst used quantitative rather than qualitative risk assessment methodology
- B) The organization's AI risk framework did not include fairness and bias as explicit risk categories
- C) The analyst failed to consult the OWASP LLM Top 10
- D) The model card was incomplete at the time of deployment

Answer: B Explanation: B is correct because the risk framework defined the scope of the analyst's assessment — if fairness and bias risks were not included as categories, the analyst had no prompt to assess them, and the resulting risk register would appear comprehensive while missing the risk that materialized. A is wrong because the assessment methodology (quantitative vs. qualitative) did not cause the missed risk category — the gap was in the framework's risk taxonomy, not the mathematical approach. C is wrong because OWASP LLM Top 10 addresses LLM-specific application security risks, not traditional ML fairness risks in credit scoring models. D is wrong because model card completeness is a documentation

concern; the root cause was missing the risk category entirely, not documenting it incorrectly.

Q2. Scenario: *An AI Risk Analyst is building the threat identification component of a risk assessment for a machine learning pipeline that processes financial transaction data to detect fraud. They need a threat library that covers AI-specific attack techniques documented from real-world adversarial ML incidents. Which threat library provides the MOST comprehensive catalog of adversarial machine learning attack patterns documented from real-world incidents?*

- A) OWASP Web Application Security Project (WASP) Top 10
- B) MITRE ATT&CK for Enterprise
- C) MITRE ATLAS v2.1
- D) NIST SP 800-53 control catalog

Answer: C **Explanation:** C is correct because MITRE ATLAS was specifically designed to address adversarial ML attack patterns — it provides a curated library of real-world adversarial ML incidents analogous to MITRE ATT&CK but focused on AI/ML systems. A is wrong because OWASP Web Application Top 10 addresses web application security risks and does not cover adversarial ML attack patterns against AI models. B is wrong because MITRE ATT&CK for Enterprise covers traditional IT threat patterns — it does not address AI-specific attacks like model evasion, poisoning, or extraction. D is wrong because NIST SP 800-53 is a security control catalog — it provides controls to implement, not a threat library of attack patterns to assess.

Q3. An AI Risk Analyst is assessing a novel AI attack technique for which no historical incident data exists. Which risk assessment approach is MOST appropriate?

- A) Quantitative assessment using probability-weighted expected loss
- B) Deferral until sufficient incident data accumulates to support quantitative modeling
- C) Qualitative assessment using severity tiers based on expert judgment
- D) Exclusion from the risk register until the threat is demonstrated in the organization's industry

Answer: C **Explanation:** C is correct because qualitative assessment using expert judgment is specifically appropriate for novel risks where empirical base rate data is not available — it allows the risk to be characterized and included in treatment planning without requiring data that does not yet exist. A is wrong because quantitative assessment requires reliable empirical data on threat likelihood and impact — applying it to a novel technique without this data produces false precision that is worse than acknowledged uncertainty. B is wrong because deferring assessment until data accumulates leaves the organization unprotected against a known threat while waiting for evidence that the threat is real. D is wrong because excluding a known threat from the risk register because it hasn't been demonstrated in the organization's industry is precisely the kind of optimism bias that risk assessment is designed to counter.

Q4. Which step of the AI risk assessment methodology specifically distinguishes AI risk analysis from traditional IT risk analysis?

- A) Asset identification
- B) Impact estimation

- C) Threat identification using AI-specific threat libraries
- D) Risk treatment prioritization

Answer: C **Explanation:** C is correct because threat identification is the step where AI-specific expertise matters most — traditional IT threat libraries (MITRE ATT&CK, OWASP Top 10) do not cover adversarial ML attack patterns, so an analyst who uses only traditional libraries will systematically miss AI-specific threats. AI-specific libraries (MITRE ATLAS, OWASP LLM Top 10) must be incorporated. A is wrong because asset identification methodology is similar in AI and traditional IT contexts — both require systematic inventory of assets under assessment. B is wrong because impact estimation methodology is also similar — the specific impact categories may differ (e.g., model bias causing discriminatory harm) but the estimation approach is standard risk methodology. D is wrong because risk treatment prioritization methodology (likelihood × impact ranking) is not fundamentally different for AI risks.

Q5. The NIST AI RMF MAP function is MOST directly operationalized by which role?

- A) AI Governance Engineer
- B) AI Security Architect
- C) AI Risk Analyst
- D) AI Auditor

Answer: C **Explanation:** C is correct because the MAP function covers categorizing AI systems, identifying applicable risks, and documenting risk context — this is precisely the AI Risk Analyst's primary function. A is wrong because the AI Governance Engineer primarily operationalizes the GOVERN function — implementing technical enforcement of policies and accountability structures. B is wrong because the AI Security Architect designs security controls, which maps more to the MANAGE function (treating risks through control implementation). D is wrong because the AI Auditor verifies that risk management processes were followed correctly — a verification function, not a risk identification function.

Q6. An AI Risk Analyst assesses that a deployed credit model carries a HIGH disparate impact risk and recommends immediate retraining. The business unit accepts the risk and proceeds with deployment. What is the analyst's MOST important responsibility at this point?

- A) Escalate to the regulator directly to report the risk acceptance decision
- B) Document the risk assessment, the recommendation, and the business unit's risk acceptance decision formally in the governance record
- C) Revise the risk assessment to reflect the business unit's lower risk tolerance
- D) Withdraw the risk finding from the risk register since the business unit has accepted it

Answer: B **Explanation:** B is correct because formal documentation of the risk assessment, recommendation, and override decision creates the audit trail that protects both the organization and the analyst. When regulatory action follows a risk event, documented evidence that the risk was identified, assessed, and reported — even if management accepted it — demonstrates the analyst fulfilled their professional obligation. A is wrong because direct escalation to the regulator bypasses organizational escalation paths and is not the analyst's role absent a legal obligation to report specific findings. C is wrong because the analyst's risk assessment reflects their professional judgment, not the business unit's preferred conclusion — revising it to accommodate management's decision compromises the integrity of the risk

program. D is wrong because accepted risks remain in the risk register — removal would hide the accepted exposure from governance oversight.

Q7. Federal Reserve guidance SR 11-7 on model risk management applies to AI/ML models in financial services. Which AI risk category does this regulation MOST directly address?

- A) Technical risk from adversarial attacks against production models
- B) Operational risk from model underperformance and model drift
- C) Reputational risk from public AI failures
- D) Strategic risk from AI vendor lock-in

Answer: B **Explanation:** B is correct because SR 11-7 focuses on model risk management — the risk that models produce incorrect outputs that lead to adverse business decisions. This is fundamentally an operational risk category: model underperformance, miscalibration, inappropriate use outside the model's valid scope, and model drift. A is wrong because SR 11-7 predates the adversarial ML threat landscape and focuses on model validity and governance, not adversarial attacks — though practitioners apply its principles to adversarial robustness as a model quality consideration. C is wrong because reputational risk is an indirect consequence of model failures that SR 11-7 may help prevent, but it is not the framework's direct focus. D is wrong because vendor lock-in is a strategic risk consideration not addressed by SR 11-7.

Q8. Which OWASP LLM Top 10 v1.1 risk is MOST relevant when evaluating a customer service chatbot that accepts and processes user-supplied text before passing it to a backend LLM?

- A) Training data poisoning
- B) Prompt injection
- C) Model denial of service
- D) Insecure plugin design

Answer: B **Explanation:** B is correct because prompt injection is the risk most directly applicable to an LLM application that accepts user-supplied text — attackers craft inputs designed to override the system's intended instructions, hijack the LLM's behavior, or extract information from the system prompt. A is wrong because training data poisoning occurs during model training, not during inference — a deployed chatbot accepting user queries is not vulnerable to training data poisoning at inference time. C is wrong because model denial of service (resource exhaustion through expensive queries) is a separate risk from prompt injection — while relevant to assess, it is not the most directly applicable risk given the described architecture. D is wrong because insecure plugin design applies to LLMs with tool-calling or plugin capabilities — the question describes a chatbot processing text and passing it to a backend LLM without mention of plugins.

Q9. An AI risk assessment identifies that an organization's image classification model used in hiring has a HIGH risk of disparate impact against protected groups. Which AI risk category does this PRIMARILY fall under?

- A) Technical risk
- B) Operational risk

- C) Compliance risk
- D) All of the above — disparate impact creates risk across multiple categories simultaneously

Answer: D **Explanation:** D is correct because disparate impact in a hiring model creates simultaneous risk across multiple categories: compliance risk (EU AI Act Annex III, Equal Employment Opportunity regulations), reputational risk (public disclosure of discriminatory hiring AI), technical risk (model output quality and fairness failures), and potentially strategic risk (regulatory action constraining AI use in hiring). SecAI+ exam questions about AI risk taxonomy often test whether candidates recognize that a single AI risk scenario typically spans multiple risk categories, requiring assessment across all relevant dimensions. A is wrong as a standalone answer because disparate impact is not only a technical risk — it creates legal, reputational, and operational exposure. B is wrong as a standalone answer because operational risk addresses availability and performance, not discriminatory output patterns. C is wrong as a standalone answer because compliance risk is one category of the disparate impact exposure, not the complete picture.

Q10. Which description BEST characterizes the relationship between the AI Risk Analyst and the AI Auditor in an organization using NIST AI RMF 1.0?

- A) The AI Auditor performs the risk assessment; the AI Risk Analyst implements the identified controls
- B) The AI Risk Analyst identifies and quantifies risks (MAP/MEASURE); the AI Auditor verifies that identified risks were treated correctly
- C) The AI Risk Analyst and AI Auditor perform the same function using different methodologies
- D) The AI Auditor reports risk findings to the AI Risk Analyst, who decides which risks to accept

Answer: B **Explanation:** B is correct because under NIST AI RMF 1.0, the AI Risk Analyst primarily operates in MAP (identifying risks) and MEASURE (quantifying them), while the Auditor's function is independent verification that the identified risks resulted in implemented, effective controls — closing the loop on the risk management cycle. A is wrong because the roles are reversed — risk analysts assess, governance engineers and security architects implement controls, and auditors verify. C is wrong because the two roles have distinct functions within the risk management cycle; they are not interchangeable. D is wrong because the audit function reports to governance stakeholders and provides independent assurance — auditors do not report risk findings to the risk analyst for acceptance decisions.